

Chapter 4 — Cryptography, Secrets, Keys, and Certificates

1. Document control

- Identifier: HAL-BVI-04
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern approved cryptographic purposes, key and secret custody, certificate lifecycle, rotation, revocation, recovery, and cryptographic agility.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 23, 27, 39-40, 43
- Book II: Chapters 23, 28, 31, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-02, CMP-17, CMP-20-25
- Book X: Chapters 4, 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Cryptography Authority, Key Custodian, Certificate Operator, Service Owner, Security Operations, Independent Assessor.

6. Normative controls

VI-CRY-04-001 — Use approved cryptographic profiles

Cryptography **MUST** use approved algorithms, modes, key sizes, protocols, libraries, and purposes recorded in the cryptographic profile; custom cryptography is prohibited.

- Applicability: all cryptographic use
- Responsible role: Cryptography Authority
- Enforcement: build and configuration policy
- Required evidence: cryptographic inventory
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-CRY-04-002 — Separate keys by purpose and domain

Keys **MUST** be separated by environment, Trust Domain, principal or workload, purpose, data classification, and cryptographic operation; reuse across incompatible contexts is prohibited.

- Applicability: all keys
- Responsible role: Key Custodian
- Enforcement: key-policy enforcement
- Required evidence: key metadata
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CRY-04-003 — Keep secrets out of ambient authority

Secrets **MUST** be referenced through governed secret services, scoped to the least audience and capability, short-lived where practical, auditable, and incapable of independently granting Authority.

- Applicability: all secrets
- Responsible role: Key Custodian
- Enforcement: secret broker and authority tests
- Required evidence: secret access evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CRY-04-004 — Protect key custody

High-impact keys **MUST** use hardware-backed or equivalently isolated custody, dual control for protected operations, non-exportability where feasible, and independently tested recovery.

- Applicability: critical keys
- Responsible role: Key Custodian
- Enforcement: custody controls and ceremony review
- Required evidence: key ceremony record
- Severity: Critical
- Exception authority: Cryptography Authority
- Protection objective: Protect HAL

VI-CRY-04-005 — Verify certificates completely

Certificate validation **MUST** verify chain, identity, purpose, constraints, time, revocation, algorithm policy, and expected Trust Domain; possession alone **MUST NOT** imply Authority or Permission.

- Applicability: all certificate use
- Responsible role: Certificate Operator
- Enforcement: validation policy tests
- Required evidence: validation event
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CRY-04-006 — Rotate and revoke safely

Rotation and revocation MUST define overlap, propagation, caches, in-flight work, offline nodes, failure behavior, receipts, and completion checks without weakening authority enforcement.

- Applicability: key and certificate changes
- Responsible role: Certificate Operator
- Enforcement: lifecycle orchestration
- Required evidence: rotation manifest
- Severity: High
- Exception authority: Cryptography Authority
- Protection objective: Both

VI-CRY-04-007 — Plan cryptographic agility

Every cryptographic dependency MUST identify replacement triggers, compatible migration path, inventory reachability, testing, rollback or forward recovery, and retained evidence.

- Applicability: all cryptographic systems
- Responsible role: Cryptography Authority
- Enforcement: annual agility review
- Required evidence: agility plan
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-CRY-04-008 — Respond to cryptographic compromise

Suspected key or issuer compromise MUST trigger containment, revocation, dependency impact analysis, reissuance, evidence preservation, and Book VIII-scoped reverification before restored trust.

- Applicability: compromise
- Responsible role: Security Operations
- Enforcement: incident playbook
- Required evidence: compromise recovery package
- Severity: Critical
- Exception authority: None
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 23, 27, 39-40, 43
- Book II: Chapters 23, 28, 31, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-02, CMP-17, CMP-20-25
- Book X: Chapters 4, 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.